

ZeToD Platform — Week 5 Bug Bounty Report

Build In Africa Program | June 2026

Prepared by: Kenneth Omoregie (Project Lead)

Overview

During Week 5 (The Hardening), the ZeToD team conducted a thorough bug review and security audit of the platform. Four critical bugs were identified, documented, and resolved. This report details each bug, the investigation process, and the fix applied.

Bug #1 — OAuth Session Not Persisting (Critical)

Field	Details
Severity	Critical
Affected Feature	Google OAuth + GitHub OAuth login
Reported By	Kenneth Omoregie (internal testing)
Status	FIXED

Description:

After tapping 'Continue with Google' or 'Continue with GitHub', users were redirected back to /login instead of /dashboard. The OAuth flow completed successfully on Supabase's side (token was returned in the URL hash) but the session was not being recognised by the frontend.

Root Cause:

Two issues combined to cause this bug: (1) ProtectedRoute.jsx was checking localStorage for a token first, then checking Supabase session — but OAuth does not write to localStorage. (2) The Supabase client was not processing the #access_token hash fragment automatically because onAuthStateChanged was not set up to handle the INITIAL_SESSION event correctly.

Fix Applied:

Rewrote ProtectedRoute.jsx to use supabase.auth.getSession() combined with onAuthStateChanged listener. Rewrote AuthCallback.jsx to use the same pattern, allowing Supabase to process the hash token automatically. Removed all localStorage token checks from the auth flow.

Files Changed:

src/components/auth/ProtectedRoute.jsx, src/pages/AuthCallback.jsx, src/lib/supabase.js

Bug #2 — Debug Route Exposed in Production (High)

Field	Details
Severity	High — Security Risk
Affected Feature	Backend API
Reported By	Week 4 Handoff Document
Status	FIXED

Description:

A debug route GET /debug-sentry was left active in the production backend (backend/index.js). This route was publicly accessible and exposed internal Sentry configuration details.

Root Cause:

Route was added during Week 3 Sentry integration for debugging purposes and was never removed before deployment.

Fix Applied:

Removed the /debug-sentry route entirely from backend/index.js. Verified removal with grep command. Redeployed backend to Render.

Files Changed:

backend/index.js

Bug #3 — JWT Secret Exposed in Handoff Document (Critical)

Field	Details
Severity	Critical — Secret Exposure
Affected Feature	Backend Authentication
Reported By	Kenneth Omoregie (document review)
Status	FIXED

Description:

The JWT_SECRET value was printed in plain text in the Week 4 Handoff PDF document. This document was shared with team members and potentially with program mentors, exposing the secret.

Root Cause:

The handoff document was created manually and included sensitive environment variable values for reference. No secret scanning was in place to catch this before sharing.

Fix Applied:

Rotated the JWT_SECRET in GitHub Actions Secrets with a new strong value. Redeployed the backend on Render to pick up the new secret. All existing sessions remain valid as Supabase handles session management independently.

Bug #4 — Dashboard Showing Generic Name (Low)

Field	Details
Severity	Low — UX Issue
Affected Feature	Dashboard
Reported By	Internal review
Status	FIXED

Description:

The dashboard displayed 'Welcome back, Developer' for all users regardless of who was logged in. The platform was not using the authenticated user's actual name from their profile.

Fix Applied:

Updated Dashboard.jsx to fetch the Supabase session on mount and display the user's full_name from their OAuth profile metadata. Falls back to 'Developer' if name is unavailable.

Files Changed:

src/pages/Dashboard.jsx

Summary

Bug	Severity	Status
OAuth Session Not Persisting	Critical	Fixed
Debug Route Exposed in Production	High	Fixed
JWT Secret Exposed in Document	Critical	Fixed
Dashboard Generic Name	Low	Fixed

All 4 bugs identified during Week 5 have been resolved and deployed to production.

Report prepared: June 2026 | ZeToD Platform | Build In Africa Program